

Agent评测、可靠性与安全

从最终答案到完整轨迹, 从提示注入到权限、信息流与持久状态

研究范围	2025-08-20 至 2026-08-19; 另列少量边界基线
语料规模	重点分析 35 篇评测/可靠性/安全论文及 14 篇工程记录
证据原则	优先论文原文、作者项目页、官方工程博客和GitHub仓库; 主张与推断分开
版本	v1.0 生成日期 2026-08-19

本报告不是排行榜。它是一套研究地图:
解释哪些结果可以相信、哪些只是方向性证据、哪些工程选择会改变结论。

本卷导航

01	评测对象与测量链
02	基准分类与年度关键结果
03	故障级联、定位与可恢复性
04	Agent威胁模型
05	提示注入、工具投毒与记忆投毒
06	沙箱、权限、监控与回滚
07	生产评测方案
08	代表论文精读卡

1. 评测对象与测量链

评测“一个Agent”实际是在评测模型、harness、工具、状态、环境和grader的组合。任何不记录的组件都会变成潜在混杂变量。年度最重要的评测共识，是从单一成功率转向测量链: 任务构造 -> 环境执行 -> 轨迹记录 -> 状态验证 -> 评分聚合 -> 统计不确定性。

环节	问题	必须保存
任务	是否真实、完整、无解题泄漏？	提示、输入对象、约束、参考状态
环境	是否可启动、版本一致、网络/依赖稳定？	镜像、应用版本、资源、时间
系统	模型+harness+工具如何配置？	版本、prompt、策略、预算、随机性
轨迹	每一步选择和结果是什么？	输入摘要、动作、参数、观察、状态diff
Grader	成功如何判定？	确定性检查、规则、人工或模型裁判
统计	差异是否超出随机和基础设施噪声？	多次运行、置信区间、成本、失败分布

四类指标

指标族	例子	回答
结果	完成率、部分得分、质量、正确且安全	回答是否达成目标
过程	工具选择/参数/顺序、验证、恢复、澄清	如何达到或错过目标
效率	token、工具调用、墙钟、计算、人审	单位成功成本
风险	违规动作、数据暴露、权限越界、不可逆影响	成功是否在可接受边界内

评测纪律

如果两个系统使用不同工具、网络、步骤上限、并行度或环境镜像，就不应把分数差直接解释为模型能力差。首先报告系统结果，再通过控制变量实验定位贡献。

2. 基准分类与年度关键结果

类型	代表	诊断能力
长时办公	OdysseyBench, CORPGEN, Ultra Long-Horizon	跨任务依赖、上下文锁定、记忆干扰
工具/MCP	MCPVerse, MCP-Bench, MCP-Atlas, TRAJECT-Bench	工具发现、参数、顺序、恢复、工具海洋
编码	SWE-CI, OmniCode, SecureAgentBench, PerfBench	维护、多语言、测试生成、安全、性能
Web/研究	DeepSearchQA, BrowseComp-Plus, SAGE	召回、停止、去重、引用、动态Web
GUI/电脑	WindowsWorld, OSWorld 2.0, NaturalGAIA	跨应用、隐藏状态、视觉精度、数百步
记忆	Evo-Memory, EvoMemBench, MemGym, GroupMemBench	写入/更新/检索、跨任务、多用户
安全	AgentLAB, ATBench, MCPTox, TAMAS	长时攻击、延迟触发、工具投毒、传播
透明度	AI Agent Index	公开设计、安全与生态披露

年度关键数字及其正确解释

来源	数字	不要误读
WindowsWorld	多应用任务成功率低于21%	跨应用和条件判断仍是能力断崖，不代表所有桌面任务都低于21%
OSWorld 2.0	最佳报告完成20.6% (500步)	任务中位人类用时约1.6小时，远难于OSWorld 1.0
GroupMemBench	最佳平均46%; BM25强	复杂记忆管线可能抹掉说话人和词汇结构
SecureAgentBench	最佳正确且安全15.2%	功能正确与安全正确是两个目标
SWE-Bench Pro审计	约30%公开任务被估计有破损	基准误差可大于模型差异
AgentLAB	644攻击样例/28环境	单轮防御无法覆盖目标漂移和记忆投毒
MCP-Atlas	36服务器/220工具/1,000任务	工具使用瓶颈已从函数格式扩展到多步能力选择
OdysseyBench	602个跨应用任务	真实与合成拆分应分别分析

排行榜为何越来越脆弱

- 领先差距缩小，但环境噪声、随机性和任务破损没有同步缩小。
- 公开仓库任务可能进入训练数据，模型会复现参考补丁而非真正泛化。
- 动态Web导致同一任务在不同日期可用信息不同。
- 模型可以识别基准或找到答案文件，造成评测意识与泄漏。
- LLM-as-judge对风格、长度、模型家族和答案顺序敏感。
- 单次pass@1忽略Agent系统固有随机性和尾部失败。

3. 故障级联、定位与可恢复性

Agent错误通常不是一个点，而是一条链: 错误观察 -> 错误假设 -> 错误计划 -> 错误工具 -> 错误状态 -> 过早完成。最终错误分类太晚。诊断应找“最早决定性步骤”：
从这里开始，在剩余预算和现有恢复策略下，成功概率已显著下降。

层	失败	控制
感知/读取	漏读、OCR/DOM错、过期状态	交叉来源、状态校验、视觉/结构双通道
目标/约束	误解、遗漏、漂移	goal contract、约束检查器
计划	错误依赖、局部贪心、无重新规划	里程碑验证、不确定性触发
工具	选错、参数错、顺序错、失败处理错	schema、dry-run、轨迹grader
记忆	摘要失真、冲突、陈旧、污染	类型、来源、写入门、重建
协调	委派错、重复、消息损失、合并冲突	能力路由、结构化交接、版本
验证	测试不足、裁判错、过早完成	多层oracle、独立验收、回归
环境	依赖、权限、网络、资源、应用漂移	环境指纹、错误分类、重放

可恢复性指标

- Detect time: 从错误发生到系统发现的步数/时间。
- Containment radius: 错误影响的任务、Agent、文件、账户和外部对象数。

- Recovery success: 在不人工重做全部工作的情况下恢复的比例。
- Rollback fidelity: 回滚后是否恢复数据、权限和外部状态。
- Repeat risk: 恢复后是否因错误记忆或技能再次发生。
- Human burden: 诊断和恢复所需人工分钟，而非只报模型token。

4. Agent威胁模型

Agent安全的核心对象是带权限的状态转换。攻击者不一定需要让模型输出有害文本，只需让不可信信息影响一个高权限动作，或把恶意内容写入持久状态，等待未来触发。

攻击面	风险	主要控制
用户输入	直接越权指令、目标伪装	身份、策略、风险分类、确认
网页/文档	间接提示注入、隐藏文本、恶意元数据	指令/数据分离、内容降权、最小权限
工具	描述投毒、返回注入、参数替换	来源签名、schema、allowlist、结果过滤
记忆	写入虚假事实、长期目标、恶意技能	写入门、来源、版本、审计、清除
多Agent	恶意/失陷Agent传播错误或索取权限	身份、能力证明、消息策略、隔离
执行环境	代码逃逸、秘密读取、横向移动	沙箱、网络隔离、短期凭证、资源限制
评测	答案泄漏、benchmark识别、grader操纵	隔离、时间切分、隐藏验证、审计
运维	日志泄密、错误配置、回滚失败	脱敏、变更控制、灾备演练

三要素模型

年度安全综述可以统一为三要素： 信息流决定不可信内容怎样进入决策；委派权限决定Agent能做什么；持久状态决定攻击能否跨时间和会话存活。安全设计应同时限制三者，而不是只在系统提示中写“忽略恶意指令”。

5. 提示注入、工具投毒与记忆投毒

攻击	机制	持续性	控制
直接注入	用户试图覆盖规则	当轮	系统/开发者策略、输入分类、拒绝
间接注入	网页/文件携带指令	读取后	把外部内容标为数据; 限权; 验证动作
工具投毒	工具描述/结果诱导调用或泄露	发现/调用	可信目录、签名、审查、返回过滤
记忆投毒	恶意内容被写入长期状态	未来多轮	高门槛写入、过期、provenance、清除
目标漂移	多步互动逐渐改变目标	长时	goal contract、定期重新确认、轨迹监控
工具链攻击	多个低风险动作组合成高风险效果	多步	跨调用策略、累积权限/影响检查

防御为什么需要组合

输入过滤无法识别所有语义攻击；系统提示会被长上下文稀释；工具allowlist无法阻止合法工具的危险组合；人工确认会疲劳；沙箱不能保护已授权云API。因此需要层叠控制： 不可信内容标记 -> 动作风险分类 -> 最小权限凭证 -> 沙箱/网络边界 -> 后置条件 -> 监控 -> 回滚/补偿。

6. 沙箱、权限、监控与回滚

层	实现	目的
文件系统	任务目录可写; 其他只读/不可见	防止跨项目和主机破坏
网络	域名/API/方法级allowlist; 默认拒绝	阻止外传和任意下载
凭证	短期、任务级、最小scope、不可直接读取	限制泄露后的影响
命令	风险分类、资源限制、禁止特权	控制代码执行
对象版本	乐观锁、idempotency key、预演	防止并发覆盖和重复副作用
监控	动作前/后策略、异常轨迹、延迟审计	检测越权、循环和目标漂移
回滚	快照、事务、补偿动作、恢复演练	降低不可避免失败的成本
人工升级	高风险、低置信、不可逆、策略冲突	保留责任和判断

权限提示的替代方案

逐个命令弹窗会把安全责任推给疲劳用户。更好的做法是预先定义能力租约：在某目录、某域名、某时间、某预算和某动作集合内自动执行；越界才确认。租约应可随时撤销，并在子Agent委派时只传递更小权限。

监控的边界

监控模型可以发现异常意图和轨迹，但也可能漏报、误报或与被监控模型共享偏差。它应作为防御纵深，不是唯一控制。高影响动作仍需确定性策略、权限边界和可回滚设计。OpenAI的内部编码Agent监控记录说明，公开的“没有真实破坏正例”不能证明未来风险为零，只能描述截至特定日期的观测。

7. 生产评测方案

步骤	要求
1 任务集	从真实日志抽样，覆盖常规、边界、失败和攻击; 隐去答案泄漏
2 环境	版本化容器/虚拟桌面; 快照状态; 记录外部依赖
3 基线	人类、强单Agent、简单workflow、当前生产版本
4 重复	每任务多次运行; 固定/变化随机性; 报置信区间
5 轨迹	动作、参数、观察、状态diff、错误、权限和费用
6 评分	确定性结果优先; 开放质量用盲审和校准裁判
7 安全	间接注入、恶意工具、记忆投毒、越权和不可逆动作
8 运营	延迟、单位成功成本、人工分钟、恢复时间、尾部失败
9 发布门	回归阈值、安全不变量、预算上限和回滚计划
10 线上	小流量、影子模式、逐级权限和持续漂移监控

一个可执行的发布判据示例

在200个代表任务、每题5次运行中： 结果成功率下界不低于当前系统；高风险违规为0；可恢复失败中位恢复时间不超过10分钟；单位可验证成功成本不上升20%以上；关键任务的人审否决率低于5%；所有回归失败有可定位轨迹。阈值应按业务风险调整，不应直接复制。

8. 代表论文精读卡

P01 | 2025-08 | long-horizon/eval | 窗口内

OdysseyBench: Evaluating LLM Agents on Long-Horizon Cross-Application Workflows

主要贡献: 300 real-use tasks plus 302 synthesized office tasks expose cross-application state and dependency failures.

阅读限制: Synthetic tasks and application versions can bias difficulty; report partial progress, not only completion.

[原文](#)

P06 | 2025-08 | security/MCP | 窗口内

MCPTox: Tool Poisoning Attacks on Real MCP Servers

主要贡献: 45 servers, 353 tools and 1,312 malicious cases demonstrate that tool metadata itself is an attack surface.

阅读限制: Attack success depends on model, tool descriptions and permission policy; do not generalize one aggregate score.

[原文](#)

P07 | 2025-08 | domain/eval | 边界基线

Finance Agent Benchmark

主要贡献: Recent SEC-filing tasks test research, calculation, provenance and synthesis under time-sensitive evidence.

阅读限制: Finance answers can be verifiable while investment conclusions remain judgment-dependent.

[原文](#)

P08 | 2025-08 | computer-use/eval | 边界基线

NaturalGAIA: Verifiable Long-Horizon GUI Tasks

主要贡献: A hierarchical framework and verifiable tasks connect GUI action sequences to measurable end states.

阅读限制: The benchmark may reward its own hierarchy; cross-harness replication is needed.

[原文](#)

P13 | 2025-08 | coding/eval | 窗口内

GitTaskBench: Code Agents on Real Repository Workflows

主要贡献: 54 tasks across seven modalities test repository use beyond patch generation.

阅读限制: Small task count limits fine-grained model ranking.

[原文](#)

P14 | 2025-08 | planning/eval | 边界基线

HeroBench: Long-Horizon Hierarchical Planning in Virtual Worlds

主要贡献: Hundreds to thousands of actions expose resource-dependency and global consistency failures.

阅读限制: Virtual-world structure is diagnostic but not a direct proxy for office or coding work.

[原文](#)

P15 | 2025-09 | reliability | 窗口内

Where LLM Agents Fail and How Errors Cascade

主要贡献: Root-cause errors propagate through planning, memory, reflection and tool modules; final failure labels hide the first decisive mistake.

阅读限制: Taxonomies are sensitive to annotator access to hidden state and intended plans.

[原文](#)

P16 | 2025-09 | long-horizon/eval | 窗口内

Benchmarking Agent Capabilities in Ultra Long-Horizon Tasks

主要贡献: Heavy settings exceed 200k tokens and 400 tool calls; simple scale fails under in-context locking and capability gaps.

阅读限制: One environment cannot settle how general the identified failure causes are.

[原文](#)

P17 | 2025-09 | interaction/eval | 窗口内

VitaBench: Versatile Interactive Tasks in Real-World Applications

主要贡献: Tests extensive information, diverse resources and dynamic user interaction in one suite.

阅读限制: Breadth can dilute causal diagnosis unless component-level metrics are retained.

[原文](#)

P19 | 2025-09 | coding/security | 窗口内

SecureAgentBench: Secure Code Generation in Real Repositories

主要贡献: Best evaluated setup achieves only 15.2% correct-and-secure solutions, showing that functional tests miss security regressions.

阅读限制: 105 tasks are valuable but insufficient to cover language and vulnerability diversity.

[原文](#)

P20 | 2025-09 | coding/eval | 窗口内

PerfBench: Can Agents Resolve Real-World Performance Bugs?

主要贡献: Performance repairs require agents to create measurements and beat developer baselines, not merely pass tests.

阅读限制: Hardware variance and noisy benchmarks can dominate small improvements.

[原文](#)

P27 | 2025-10 | security/survey | 窗口内

Agentic AI Security: Threats, Defenses and Evaluation

主要贡献: Organizes prompt injection, tool abuse, memory attacks and governance into a systems threat model.

阅读限制: Survey evidence mixes proofs, synthetic attacks and deployment reports of unequal strength.

[原文](#)

P28 | 2025-10 | tools/eval | 窗口内

TRAJECT-Bench: Trajectory-Aware Tool-Use Evaluation

主要贡献: Separates tool selection, arguments, dependency order and final answer to expose parameter-blind choices.

阅读限制: Reference trajectories are not always unique; outcome-equivalent alternatives require careful grading.

[原文](#)

P29 | 2025-11 | memory/eval | 窗口内

Evo-Memory: Test-Time Learning with Self-Evolving Memory

主要贡献: A streaming benchmark compares more than ten memory modules across task sequences and makes update policy measurable.

阅读限制: Cross-dataset aggregation can hide incompatible memory objectives.

[原文](#)

P32 | 2025-11 | multi-agent/security | 窗口内

TAMAS: Adversarial Risks in Multi-Agent LLM Systems

主要贡献: Demonstrates that adversarial influence can propagate across role and message boundaries.

阅读限制: Threat success rates are topology- and defense-specific.

[原文](#)

P33 | 2025-11 | multi-agent/reliability | 窗口内

Detecting Silent Failures in Multi-Agent Trajectories

主要贡献: Treats silent failure as trajectory anomaly detection rather than final-answer error.

阅读限制: Detection does not automatically yield correct attribution or recovery.

[原文](#)

P37 | 2025-12 | eval/reliability | 窗口内

Beyond Task Completion: Agent Assessment Framework

主要贡献: Four pillars cover model, memory, tools and environment, revealing runtime deviations missed by binary success.

阅读限制: One CloudOps validation case limits generalization.

[原文](#)

P41 | 2026-01 | research/eval | 窗口内

DeepSearchQA: Comprehensiveness for Deep Research Agents

主要贡献: 900 prompts in 17 fields test exhaustive collection, de-duplication, entity resolution and stopping.

阅读限制: Open-web ground truth and answer sets require continual maintenance.

[原文](#)

P42 | 2026-01 | tools/reliability | 窗口内

When Agents Fail to Act: Tool Invocation Reliability

主要贡献: 1,980 deterministic tests across models and hardware classify 12 procedural error types.

阅读限制: Tool initialization results may not transfer to complex reasoning-heavy workflows.

[原文](#)

P43 | 2026-02 | tools/eval | 窗口内

MCP-Atlas: Real MCP Server Tool Competency

主要贡献: 36 servers, 220 tools and 1,000 tasks use claims-based partial credit and internal diagnostics.

阅读限制: Claims scoring still needs validation against actual external state changes.

[原文](#)

P44 | 2026-02 | security/eval | 窗口内

AgentLAB: Long-Horizon Attacks

主要贡献: 644 cases across 28 environments cover intent hijacking, tool chaining, task injection, objective drift and memory poisoning.

阅读限制: Attack realism depends on whether adversaries can actually reach those channels in deployment.

[原文](#)

P48 | 2026-02 | coding/eval | 窗口内

OmniCode: Broad Software Engineering Agent Evaluation

主要贡献: 1,794 tasks span bug fixes, test generation, review fixes and style work in Python, Java and C++.

阅读限制: Synthetic and recent tasks improve contamination resistance but change ecological realism.

[原文](#)

P50 | 2026-03 | security/survey | 窗口内

Clawed and Dangerous: Trusting Open Agentic Systems

主要贡献: A six-dimensional taxonomy argues that behavior governance under uncertainty is the central security problem.

阅读限制: A systematization of knowledge should not be read as empirical proof of every control.

[原文](#)

P51 | 2026-04 | security/eval | 窗口内

ATBench: Realistic Trajectory Benchmark for Long-Horizon Safety

主要贡献: 1,000 audited trajectories organize risks by source, failure mode and harm with delayed triggers.

阅读限制: Average trajectories remain shorter than many production tasks.

[原文](#)

P52 | 2026-04 | computer-use/eval | 窗口内

WindowsWorld: Cross-Application Professional GUI Agents

主要贡献: 181 tasks across 17 apps show under 21% success on multi-application workflows and early stalling beyond three apps.

阅读限制: Windows configuration and automation interfaces materially affect results.

[原文](#)

P53 | 2026-05 | memory/eval | 窗口内

GroupMemBench: Memory in Multi-Party Conversations

主要贡献: Best system reaches only 46%; BM25 matches or beats many agent memories when speaker structure and terminology matter.

阅读限制: Synthetic group conversations may not capture organizational power and privacy constraints.

[原文](#)

P54 | 2026-05 | memory/eval | 窗口内

EvoMemBench: Memory from a Self-Evolving Perspective

主要贡献: Across 15 methods, long context remains competitive and no memory form wins all settings.

阅读限制: Benchmark parity depends on equalizing token, latency and storage budgets.

[原文](#)

P55 | 2026-05 | memory/eval | 窗口内

MemGym: Long-Horizon Memory Environment

主要贡献: Unifies tool dialogue, deep research, coding and computer use with memory-isolated scores.

阅读限制: Reward-model proxies can diverge from expensive end-to-end rollouts.

[原文](#)

P60 | 2026-06 | security/survey | 窗口内

Toward Secure LLM Agents: Threat Surfaces and Defenses

主要贡献: Synthesizes 247 papers around information flow, delegated authority and persistent state.

阅读限制: Fast-moving evidence means control effectiveness should be re-audited per release.

[原文](#)

P61 | 2026-06 | computer-use/eval | 窗口内

OSWorld 2.0: Long-Horizon Real-World Computer Use

主要贡献: 108 workflows take humans a median 1.6 hours; the best reported system completes only 20.6% at 500 steps.

阅读限制: Benchmark environments are expensive and sensitive to application state.

[原文](#)

P64 | 2026-07 | reliability/survey | 窗口内

Beyond the Leaderboard: Tool, Planning and Reasoning Failures

主要贡献: Across 19 benchmarks, failures compound nonlinearly and more scaffolding does not consistently improve reliability.

阅读限制: Cross-paper taxonomies inherit inconsistent setups and metrics.

[原文](#)

P65 | 2026-07 | multi-agent/reliability | 窗口内

AgentLocate: Failure Localization in Multi-Agent Systems

主要贡献: Attributes both the responsible agent and earliest decisive step using multi-perspective verification.

阅读限制: LLM judges may share biases with the target system and need human calibration.

[原文](#)

P66 | 2026-08 | coding/reliability | 窗口内

Engineering Reliable Coding Agents

主要贡献: A multivocal system-level review treats evaluation, harness, state, permissions and infrastructure as a dependency chain.

阅读限制: Evidence quality varies across scholarly and practitioner records; practices are hypotheses until workload-tested.

[原文](#)

P69 | 2025-06 | interaction/eval | 边界基线

tau2-bench: Dual-Control Conversational Agents

主要贡献: Shared user-agent control causes large performance drops and exposes communication as a distinct capability.

阅读限制: Published before the strict window; retained only as a baseline used by later work.

[原文](#)

P70 | 2025-08 | research/eval | 边界基线

BrowseComp-Plus: Reproducible Deep-Research Evaluation

主要贡献: A fixed corpus and verified supports disentangle retrieval from reasoning and improve comparison fairness.

阅读限制: Published 12 days before the strict window; included as a boundary baseline.

[原文](#)

本卷结论

可靠Agent不是从不犯错，而是错误能被早发现、限制影响、准确定位、恢复并避免写入长期状态。安全也不是一段拒绝提示，而是围绕信息流、权限和持久状态建立的系统控制。